

INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY (ICDFA)

GRC102: Information Security Governance

Week 3 Practical Laboratory: Roles and Responsibilities in Security Governance (TechGlobal)

Full Name	Rosemary Gift Nelson
Registration Number	C11/26/CGRCE/17216
Cohort / Batch	Cohort 11 / Batch A
Course	GRC102: Information Security Governance
Assessment	Week 3 Practical Laboratory: Roles and Responsibilities in Security Governance (TechGlobal)
Date Submitted	25th September 2026

I handled this lab as TechGlobal's newly appointed Lead Security Governance Consultant. A 2,500-person organisation spread across five offices has genuinely outgrown a model where one IT Director makes every security call alone, and the six evidence bundles below rebuild that model from the ground up, starting with the architecture itself.

Evidence Bundle 1: Governance Architecture

Governance Gap Assessment

Weakness	Governance Issue	Business Impact
Security decision authority concentrated in the IT Director	One person carries both the operational duty of running security controls and the governance duty of deciding what good security looks like, with no separate body checking those decisions.	Decisions reflect one individual's judgement and workload rather than a considered, business-wide view, and TechGlobal has no way of knowing whether that judgement is actually sound until something goes wrong.
No formal security governance committee structure	There is nowhere for Legal, Finance, HR, Risk and the business to weigh in on a security decision before it is made, so IT effectively governs itself.	Cross-functional risk, a regulatory exposure Legal would have flagged, or a budget conflict Finance would have raised, only surfaces after a decision has already been acted on.
Inconsistent security decisions across the five regional offices	Each regional office is making its own local calls on security matters, with no shared	The same risk could be accepted five different times in five different ways, and an

	standard and no central visibility of what any other office has decided.	incident in one office may not trigger any protective action in the other four until it is too late.
Limited executive and Board visibility into cyber risk	Leadership has no structured, recurring reporting on the organisation's security posture, so oversight depends on whatever happens to be volunteered rather than a defined reporting cycle.	The Board cannot exercise real oversight of a risk it is not being shown, and it will only become urgently visible to them the day an incident forces the conversation.
No documented decision-authority or accountability model	TechGlobal has never written down who is actually accountable for a given security decision, so in practice it defaults to whoever is available or most senior in the room at the time.	Decisions become slower and less consistent, and after an incident it becomes genuinely difficult to establish who should have caught the problem, which weakens both learning and accountability.
No escalation path connecting regional offices to central governance	A material risk discovered in one office has no defined route to reach central leadership, so it stays local by default rather than by design.	A risk that should trigger an organisation-wide response instead sits unnoticed outside the office where it was found, and TechGlobal's five-region footprint turns from a growth story into five separate blind spots.

Stakeholder Map

I mapped every party with a real stake in TechGlobal's security governance, not just the ones already in the room, since two of the biggest gaps in the current model, Legal and the five regional offices, are exactly the stakeholders who are currently missing from the picture entirely.

Stakeholder	Governance Interest	Current Involvement	Needed Involvement
Board of Directors	Ultimate accountability for enterprise risk, including cyber risk, to shareholders.	None, no cyber-specific reporting reaches the Board.	Quarterly structured reporting and formal approval of risk appetite.
Chief Executive Officer	Overall accountability for the organisation's risk	Informal, only made aware of issues the IT	Regular briefings and final executive sign-off

Stakeholder	Governance Interest	Current Involvement	Needed Involvement
	posture and resourcing of the security function.	Director chooses to escalate.	on material risk decisions.
IT Director	Currently the sole owner of both technical delivery and security decision-making.	Total, but unchecked by any governance body.	Retained as a key operational partner, no longer the sole decision authority.
CISO (role to be established)	Would own the security governance programme and translate Board direction into action.	Does not currently exist as a role.	Established as a dedicated function reporting with functional access to the Board.
Chief Risk Officer / Enterprise Risk	Ensures cyber risk is assessed using the same rigour as every other enterprise risk.	Not currently consulted on security matters.	Standing seat on the Security Governance Committee and enterprise risk register ownership.
Legal / Privacy / Compliance	Protects TechGlobal from regulatory and legal exposure arising from security decisions or incidents.	Consulted only after an incident, if at all.	Involved at the point of decision, not only after the fact.
Finance	Approves and tracks the cost of the security programme and any incident's financial impact.	Receives budget requests with little supporting risk justification.	Standing seat on the Security Governance Committee with visibility into risk-based investment cases.
Human Resources	Owns the joiner, mover and leaver process that access provisioning depends on, and disciplinary outcomes.	Operates independently of IT's access processes.	A defined, synchronised handoff with IT for every access change.
Regional Business Unit Leaders (five offices)	Responsible for security practice within their own office and business line.	Making independent decisions with no	Represented in governance through a Regional Security

Stakeholder	Governance Interest	Current Involvement	Needed Involvement
		central coordination.	Forum feeding into the central committee.
Internal Audit	Provides independent assurance that governance controls are actually operating.	No defined role in the current model.	Independent review of the governance model itself, not only of individual controls.
Employees (all offices)	Expected to follow security policy and report concerns.	Working without a consistent, communicated standard to follow.	A single, clearly communicated policy and escalation channel regardless of office.

Proposed Security Governance Organisation Chart

The chart below keeps the IT Director as a critical technical partner while removing sole decision authority from that role, and it gives TechGlobal's five offices a defined channel into central governance through a Regional Security Forum, rather than leaving each office to decide security matters on its own.

Level	Role / Body	Reports To	Core Mandate
1	Board of Directors / Risk and Audit Committee	Shareholders	Approves risk appetite and security strategy, receives quarterly assurance on the governance programme.
2	Chief Executive Officer	Board of Directors	Holds overall accountability for TechGlobal and sponsors the governance programme across all five offices.
3	Chief Information Security Officer (new role)	CEO administratively; Board functionally for material risk	Owns the governance programme end to end, chairs the Security Governance Committee, and reports risk posture upward.
4	Security Governance Committee (CISO chair; CRO; Legal; Finance; HR; IT Director; two rotating	CISO administratively; CEO for escalated decisions	Cross-functional prioritisation, policy approval, and resolution of conflicts between functions or regions.

Level	Role / Body	Reports To	Core Mandate
	Regional Business Unit Leaders)		
5	Regional Security Forum (one liaison per office: North America, Europe, Asia-Pacific, Latin America, and Middle East/Africa)	CISO, with a dotted line to the respective Regional Business Unit Leader	Surfaces local risk and decisions to the centre, and carries central policy back out to each office.
6	Security Operations and Technical Delivery (led by the IT Director)	CISO for governance direction; retains technical operational reporting	Implements approved controls and manages day-to-day technical security work across all offices.

Consultant Justification

TechGlobal's problem is not a shortage of security effort. The IT Director and the technical team are clearly doing real work; the problem is that this effort has never been organised into governance. Every one of the six gaps I identified traces back to the same root cause: no structure exists to check, coordinate, or escalate the decisions IT is already making, and nothing connects those decisions to the Board, to Legal, to Finance, to HR, or across TechGlobal's own five offices.

The structure I am proposing addresses this directly rather than by adding process for its own sake. Creating a dedicated CISO role, reporting administratively to the CEO but with functional access to the Board for material risk, separates governance from operations without sidelining the IT Director, who remains essential to actually running security day to day. The Security Governance Committee gives Legal, Finance, HR, Risk and the business a standing seat at the table before a decision is made, not a chance to react afterward. The Regional Security Forum is the piece I consider most specific to TechGlobal's actual situation: with five offices already making inconsistent decisions, a central governance model that ignores the regional dimension would solve the accountability problem on paper while leaving the original inconsistency untouched. Giving each office a named liaison into the centre, rather than requiring every regional matter to escalate all the way to the CISO personally, keeps the model workable at TechGlobal's scale.

I also deliberately kept the structure to six levels rather than building something more elaborate, because a governance model TechGlobal's own people cannot describe from memory is one they will quietly stop using within a year. Every layer in this chart exists to close a specific gap identified above: the Board and CEO layers close the visibility gap, the CISO and Security Governance Committee layers close the concentration-of-power and cross-functional gaps, and the Regional Security Forum closes the inconsistency gap between offices. Nothing here is decorative, and I would defend every layer of it in front of TechGlobal's Board on that basis.

Evidence Bundle 2: Roles and Responsibilities

Cross-Functional Governance Responsibility Matrix

Role	Decision Authority	Primary Accountability	Reports To / Interacts With
Board of Directors	Approves risk appetite and security strategy; final authority on risk beyond the CEO's delegated limit.	Ensuring TechGlobal governs cyber risk with the same rigor as any other enterprise risk.	Reports to shareholders; receives quarterly input from the CISO.
Chief Executive Officer	Approves the security budget within Board limits; makes the final call on incidents below Board threshold.	TechGlobal's overall risk posture and the credibility of the governance programme.	Reports to the Board; receives ongoing updates from the CISO.
Chief Information Security Officer	Owns strategy, policy and the risk register; chairs the Security Governance Committee.	Giving the Board and CEO an honest, evidence-based picture of TechGlobal's security posture.	Reports administratively to the CEO and functionally to the Board; works with all other roles listed here.
Chief Risk Officer / Enterprise Risk	Owns the enterprise risk methodology cyber risk is assessed against.	Keeping cyber risk in the same risk language as every other enterprise risk category.	Reports to the Board Risk Committee; consulted by the CISO on risk rating.
Legal / Privacy / Compliance	Decides whether a regulatory notification is triggered; owns external disclosure wording.	Keeping TechGlobal inside its legal and regulatory obligations across all five jurisdictions it operates in.	Reports to the Security Governance Committee and, where material, directly to the Board.
Finance	Approves the security budget within CEO/Board limits; decides how incident costs are recorded.	Making sure security is funded in proportion to the risk TechGlobal actually carries.	Reports incident cost and programme spend to the CEO and, where material, the Board.
Human Resources	Owns disciplinary outcomes from confirmed violations; controls the joiner/mover/leaver process.	Keeping access aligned to actual employment status across all five offices.	Coordinates directly with IT on every access change; reports patterns to the Security Governance Committee.
IT Director / Technology Operations	Decides how an approved control is implemented technically; owns technical incident remediation.	Operating the controls the CISO's policy requires, and confirming, not merely claiming, that they work.	Reports control and incident status to the CISO; retains technical operational reporting lines.

ROLE PROFILES

Board of Directors

The Board's job here is not to understand every technical detail of TechGlobal's security programme, it is to set the boundary of acceptable risk and then hold the CEO and CISO to it. In a five-office organisation this matters more than it might in a single-site business, since the Board is the only body positioned to see the full picture across all regions at once rather than one office's local view.

Chief Executive Officer

The CEO sits between the CISO and the Board, and in practice becomes the tie-breaker whenever Legal, Finance, HR, Risk and IT cannot agree on a cross-functional security matter. Given TechGlobal's growth, I expect this role to be tested early, most likely the first time a regional office pushes back on a global security requirement it sees as slowing local business down.

Chief Information Security Officer

This is the role TechGlobal does not yet have, and its absence is the single clearest explanation for every gap identified in Bundle 1. I am recommending the CISO sit outside the IT Director's reporting line entirely, chairing the Security Governance Committee and owning the risk register directly, so that security governance stops depending on the goodwill of whoever happens to be running IT operations at the time.

Chief Risk Officer / Enterprise Risk

TechGlobal does not appear to have engaged its enterprise risk function on cyber matters at all so far. Bringing the CRO into the Security Governance Committee closes that gap and gives the CISO a shared language for comparing cyber risk against every other risk category the Board already tracks.

Legal / Privacy / Compliance

With operations spanning five regions, TechGlobal is very likely subject to more than one data protection or breach notification regime at once. Legal's seat on the committee exists specifically so that regulatory exposure is considered at the point a security decision is made, not discovered afterward when a deadline has already started running in a jurisdiction nobody checked.

Finance

Finance currently receives budget requests from IT with little risk justification behind them, which is really a governance gap dressed up as a financial one. Giving Finance a standing seat on the committee means investment decisions get made with the same risk information the CISO is working from, not a separate, thinner version of it.

Human Resources

HR's role is easy to underestimate because it looks purely administrative, but the joiner, mover and leaver process HR owns is the operational backbone of every access control TechGlobal has. Across five offices in different time zones, this handoff needs to be explicit and synchronized, not assumed.

IT Director / Technology Operations

None of this model works if the IT Director is treated as the problem to be removed. The role remains essential, it simply stops being the only voice in the room. Separating governance from operations here is exactly what lets the IT Director focus on running security well, instead of also being solely responsible for deciding what well means.

Conflict-Resolution Analysis

The most likely conflict in this model is not between TechGlobal's central functions, it is between the centre and a regional office. Picture the Asia-Pacific office wanting to move faster on a product launch than the global security standard allows, while the IT Director insists the standard cannot be waived. Under the current arrangement, that disagreement has nowhere to go except an informal argument that whoever is more senior or more persistent usually wins.

Under the proposed model, that same disagreement goes to the Security Governance Committee as a formal agenda item, with the Regional Security Forum liaison representing the office's business case and the IT Director or CISO representing the security position. The Committee weighs both, and where it cannot reach agreement within one meeting cycle, the CISO escalates the decision to the CEO with both positions documented, exactly as set out in the escalation workflow in Bundle 5. This does two things at once: it stops a regional office from simply overriding central policy on its own authority, and it stops the Centre from imposing a requirement without ever having to justify it against a real business case. Both sides are heard, and the decision is made once, by the right people, instead of being re-litigated informally every time it comes up.

EVIDENCE BUNDLE 3: GOVERNANCE COMMITTEE ECOSYSTEM

Committee Interaction Diagram

I have set this out as a table rather than a freeform diagram, since a table lets me show exactly what flows between each body, which a picture with arrows tends to flatten into a vague sense of connection.

Committee / Body	Purpose	Feeds Into	Receives Input From
Board Risk and Audit Committee	Sets risk appetite, approves strategy, receives assurance.	Board of Directors	Security Governance Committee (quarterly report)
Security Governance Committee	Cross-functional prioritisation, policy approval, conflict resolution.	Board Risk and Audit Committee; CEO	Regional Security Forum; Incident Response Team
Regional Security Forum	Surfaces local risk and decisions from each of the five offices into central governance.	Security Governance Committee	Regional Business Unit Leaders; local IT teams
Incident Response Team	Executes technical containment and recovery during an active incident.	Security Governance Committee (post-incident review); CISO (real-time)	SOC/IT operations; whichever office reports the incident

Security Governance Committee Terms of Reference

Section	Detail
Purpose	To provide TechGlobal with a structured, cross-functional forum for approving security policy, prioritising investment, and resolving disagreements between central governance and any of the five regional offices, so these matters are settled through governance rather than informal seniority.
Scope	All TechGlobal security policy, risk treatment prioritisation, cross-functional or cross-regional conflicts, and review of incidents with organisation-wide relevance.
Membership	Chief Information Security Officer (Chair), Chief Risk Officer, a Legal/Compliance representative, a Finance representative, a Human Resources representative, the IT Director, and two Regional Business Unit Leaders on a rotating basis representing the five offices between them.
Responsibilities	Review and recommend security policy for CEO approval; maintain oversight of the enterprise risk register; resolve cross-functional and cross-regional disagreements using documented evidence rather than positional authority; review incident lessons learned; recommend investment priorities to the CFO and CEO.

Section	Detail
Meeting Cadence	Monthly standing meeting, with authority to convene an additional session within three business days for an urgent conflict or a material incident.
Decision Authority	The Committee seeks consensus. Where consensus is not reached within one meeting cycle, the Chair escalates the matter to the CEO with both positions documented, for a decision within five business days.
Reporting	Minutes and a decisions log go to the CEO monthly. A summary of material decisions and the risk register go to the Board Risk and Audit Committee quarterly.

Sample Meeting Agenda

1. Welcome, roll call, and review of actions from the previous meeting.
2. Regional Security Forum update: risk items raised by any of the five offices since the last meeting.
3. Review of the enterprise risk register, including any item approaching its review date.
4. Key discussion item: the Asia-Pacific penetration testing exception request (see Decision Log, Decision 1).
5. Incident summary since the last meeting, including any post-incident review findings.
6. Budget and investment items for Finance to present or the Committee to recommend.
7. Policy items requiring review or recommendation for CEO approval.
8. Any other business, and confirmation of the next meeting date.

Sample Decision Log

#	Date	Issue Considered	Decision	Owner	Rationale
1	3 Nov 2026	Asia-Pacific office requested an exception to launch a new customer portal ahead of completing the standard third-party penetration test.	Exception denied. The portal may launch once the penetration test is complete or a compensating control (a 30-day web application firewall rule set) is in place, whichever is sooner.	CISO	The portal handles customer payment data; the Committee judged the residual risk of skipping testing entirely too high relative to a short compensating measure.
2	17 Nov 2026	Proposal to fund an organisation-wide multi-factor authentication rollout across all five offices.	Approved, phased over two quarters, starting with the two offices showing the highest phishing-incident volume.	Finance, with CISO	Risk-based sequencing was judged more defensible to the Board than a single simultaneous rollout the budget could not fully support in one quarter.

#	Date	Issue Considered	Decision	Owner	Rationale
3	8 Dec 2026	A new cloud analytics vendor proposed by the Latin America office had not completed TechGlobal's standard vendor risk assessment.	Conditional approval: vendor may be used for non-Restricted data only until the assessment is complete, reviewed again in 60 days.	Legal, with CISO	This let the business proceed without a full stop, while keeping Restricted data out of an unassessed environment until due diligence was actually finished.

12-Month Governance Calendar

Month	Governance Activity
January	Annual risk appetite statement reviewed and recommended to the Board for approval.
February	Security Governance Committee reviews prior-year metrics and sets the year's priorities.
March	Q1 Board Risk and Audit Committee report; Regional Security Forum reviews local risk registers.
April	Annual policy review cycle begins; RACI matrix reviewed for currency.
May	Security awareness training completion review across all five offices.
June	Q2 Board Risk and Audit Committee report.
July	Mid-year internal audit of governance controls; escalation log reviewed for patterns.
August	Regional Security Forum cross-office review; vendor risk register reconciliation.
September	Q3 Board Risk and Audit Committee report; annual tabletop exercise for major incident escalation.
October	Budget planning for the following year, informed by the year's risk register and incident data.
November	Policy annual review cycle concludes; updated policies go to the Committee for recommendation.
December	Q4 Board Risk and Audit Committee report; annual governance model effectiveness review.

EVIDENCE BUNDLE 4: RACI ACCOUNTABILITY MATRIX

The matrix below covers sixteen governance activities, one more than the fifteen required, because reviewing TechGlobal's role model in Bundle 2 convinced me that business continuity planning needed its own line rather than being folded into incident response, since the two activities have genuinely different decision owners and different timing.

Governance Activity	Board	CEO	CISO	CRO	Legal	Finance	HR	IT
Security strategy approval	A	C	R	C	I	C	I	I
Enterprise security policy approval	I	A	R	C	C	I	C	C
Regional security exception approval	I	I	A	I	C	I	I	C
Privileged access approval	I	I	A	I	I	I	I	R
Third-party / vendor risk acceptance	I	I	R	A	C	C	I	C
Security budget approval	I	C	R	C	I	A	I	C
Incident response activation	I	C	A	C	C	I	C	R
Regulatory breach notification	I	C	R	I	A	I	I	I
Security awareness training approval	I	I	A, R	I	C	I	C	I
Disciplinary action for policy violation	I	I	R	I	C	I	A	I
New system / product security sign-off	I	I	A	C	C	I	I	R
Enterprise risk register maintenance	I	I	A, R	C	C	I	I	C
Board cyber-risk reporting	I	C	A, R	C	I	I	I	I

Governance Activity	Board	CEO	CISO	CRO	Legal	Finance	HR	IT
Security metrics and KPI approval	I	C	A	C	I	I	I	C
Business continuity / disaster recovery plan approval	I	A	R	C	C	C	C	R
Major partnership or acquisition security due diligence	I	A	R	C	C	C	I	C

Implementation Guide: How Management Should Use This Matrix

This matrix is only useful if it changes how a decision actually gets made, so I am setting out here exactly how I expect TechGlobal's management to use it, not just what it says.

Before any activity on this list happens, the person initiating it should check the matrix first, not after the fact. If you are the Accountable role for an activity, the decision does not proceed without your sign-off, and if you are marked Responsible, you are the one actually doing the work, even if someone else is accountable for the outcome. Being marked Consulted means your input must be sought before the decision is made, not simply noted afterward, and being marked Informed means you have a right to know the outcome but no right to block it, a distinction that matters most during the regional exception disputes described in Bundle 2's conflict analysis.

Where two people disagree about who owns a decision, the matrix is the answer, not a fresh negotiation. This is precisely why every row carries exactly one Accountable role: a shared or ambiguous Accountable column would recreate the same confusion this whole exercise exists to remove. Where the CISO is marked as both Accountable and Responsible, for training approval, the risk register, and Board reporting, that reflects activities where ownership and execution genuinely sit with the same person, not an oversight in the design.

Finally, this matrix is not permanent. I am recommending the Security Governance Committee review it annually, in April as set out in the governance calendar in Bundle 3, and immediately after any incident or structural change, such as the creation of a new regional office, that the current matrix does not clearly account for. A RACI matrix that never changes eventually stops matching how the organisation actually works, and at that point it does more harm than good, since people will keep citing an authority structure that no longer reflects reality.

EVIDENCE BUNDLE 5: CYBER-RISK ESCALATION

Major Cyber-Risk Escalation Workflow

TechGlobal's five-office footprint is exactly why I have built time zone handling into this workflow rather than treating it as a detail to sort out later. An incident discovered in Asia-Pacific at the start of its working day may need to reach a CISO who is asleep in a different time zone, so the workflow below assumes a follow-the-sun handoff rather than a single point of failure in one person's inbox.

- 1. **Detection:** the office where an anomaly or incident is first identified logs it immediately through the standard incident channel, regardless of local time.
- 2. **Local triage:** the Regional Security Forum liaison for that office assesses severity against the threshold table below within one hour of detection.
- 3. **Tier assignment:** the liaison assigns the incident to Operational, Executive, or Material/Board tier based on the defined criteria, and if genuinely uncertain, defaults upward rather than downward.
- 4. **Operational tier handling:** the local team manages the incident directly and logs the outcome; no further escalation is required unless the situation changes.
- 5. **Executive tier escalation:** the liaison notifies the CISO directly, using an out-of-hours contact protocol if the CISO's own office is outside working hours, and the CISO takes ownership of coordination across any other affected office.
- 6. **Material/Board tier escalation:** the CISO notifies the CEO immediately, and jointly they brief the Board Risk and Audit Committee within 24 hours, activating Legal and Finance in parallel rather than sequentially, so regulatory and financial assessment begins at the same time as technical containment.
- 7. **Cross-office coordination:** where an incident touches more than one office, the CISO becomes the single coordinating point, so each affected office is not left independently deciding its own response to what is actually one connected incident.
- 8. **Closure and review:** every Executive or Material tier incident receives a documented post-incident review, with lessons reported to the Security Governance Committee and reflected in the enterprise risk register.

Escalation Threshold Table

Tier	Definition / Criteria	Example	Decision Authority	Notification Timing
Operational	A risk or incident that stays within a single	A phishing email caught and contained	Local IT team / Regional	Logged within 24 hours; no

Tier	Definition / Criteria	Example	Decision Authority	Notification Timing
	office's normal capacity to manage, with no regulatory, cross-office, or Board-level implication.	by the local security team within one office, with no data accessed.	Security Forum liaison	upward escalation required.
Executive	A risk or incident that exceeds one office's containment capacity, affects more than one office, or carries a defined cost or regulatory exposure below the Board's material threshold.	A malware infection that spreads from one office's network segment toward a second office before containment.	CISO, with the CEO informed and consulted	CISO notified within 4 hours of confirmation; CEO briefed within 24 hours.
Material / Board-Level	A risk or incident that exceeds the Board-approved risk appetite, involves a confirmed data breach, triggers a regulatory notification obligation in any jurisdiction, or carries material financial or reputational consequence.	A confirmed breach of customer data originating from any of the five offices, or a ransomware incident affecting core systems.	Board Risk and Audit Committee, briefed by the CEO and CISO	Board notified within 24 hours of confirmation; formal Board decision within 5 business days, or sooner if a regulatory deadline requires it.

The rule that matters most in this table is the direction of uncertainty. Every tier assignment that could reasonably go either way should be assigned to the higher tier, not the lower one, because the cost of an unnecessary escalation is a wasted meeting, while the cost of a missed one is a regulatory deadline or a spreading incident nobody at the centre knew to coordinate.

Evidence Bundle 6: Segregation of Duties and Accountability

I identified six conflicts rather than the minimum five, because the sixth, the regional version of the same self-review problem that shows up centrally in Weakness 1, only became visible to me once I had mapped the Regional Security Forum in Bundle 1. It felt dishonest to design a five-office layer of governance and then not check it for the exact conflict I had just flagged at the centre.

#	Weakness / Conflict	Associated Risk	Roles Involved	Corrective Control	Residual Risk Consideration
1	The IT Director both operates TechGlobal's security controls and is currently the sole approver of security-related decisions, with no independent body reviewing those decisions.	A decision could favour operational convenience over actual risk reduction, and no one is positioned to catch it if it does.	IT Director	Security decision authority moves to the CISO and the Security Governance Committee, with the IT Director remaining the operational executor rather than the approver.	Some residual reliance on the IT Director's technical judgement remains for implementation detail, which is acceptable since that detail is no longer where governance decisions are made.
2	Regional business unit leaders can approve local security exceptions independently, with no central visibility of what any other office has approved.	The same risk could be accepted five separate times in five different ways, with no one at the centre able to see the pattern.	Regional Business Unit Leaders; CISO	All exceptions are logged centrally through the Regional Security Forum and reviewed by the CISO, with regional approval authority limited to Operational-tier matters only.	A short window between a local approval and central visibility remains, acceptable if the exception log is reviewed weekly rather than monthly.
3	HR and IT offboarding are not synchronised across the five regional time zones, so an employee terminated in one office may retain system access	A terminated employee could retain functioning access for a period after their employment formally ends.	Human Resources; IT	A same-day offboarding trigger is built into the joiner/mover/leaver process regardless of which office initiates it, with automated access revocation rather than a	Automation reduces but does not eliminate timing risk entirely; a 24-hour maximum window remains as an accepted residual

#	Weakness / Conflict	Associated Risk	Roles Involved	Corrective Control	Residual Risk Consideration
	administered from another.			manual, office-specific request.	risk, monitored monthly.
4	Incident response is currently handled solely within IT, with Legal and Risk notified only after technical resolution is complete.	A regulatory notification deadline could start running before Legal is even aware an incident occurred.	IT; Legal; Chief Risk Officer	The escalation workflow in Bundle 5 activates Legal and the CRO in parallel with technical containment for any Executive or Material tier incident, not after it.	For Operational-tier incidents, Legal is not activated by design, which is an accepted residual risk given these incidents carry no regulatory implication by definition.
5	Finance approves security budget requests without independent validation of whether previous investment actually reduced risk as claimed.	Investment decisions rely on self-reported effectiveness from the same function requesting further funding.	Finance; CISO	Security programme effectiveness metrics presented to Finance and the Committee are reviewed by Internal Audit before being used to support a new budget request.	Internal Audit's own capacity is limited, so this control operates on a sampling basis rather than reviewing every metric, an accepted residual risk given audit resourcing.
6	A Regional Security Forum liaison who administers local access in their office would also, without a separate check, be the one confirming that office's own access reviews were completed properly.	Excessive or unauthorised local access could go undetected because the same person benefits from an easy review.	Regional Security Forum liaisons	Access reviews for each office are independently verified by the CISO's team or Internal Audit on a quarterly basis, separate from the liaison administering the access.	This adds a quarterly, not continuous, check, so access misuse between review cycles remains a residual risk considered acceptable given the quarterly cadence.

REFERENCES

International Cybersecurity and Digital Forensics Academy. (2026). GRC102 Week 3: Roles and responsibilities in security governance [Course slides]. ICDFA E-Campus.

International Cybersecurity and Digital Forensics Academy. (2026). GRC102 Week 3 practical laboratory: Roles and responsibilities in security governance [Assessment brief]. ICDFA E-Campus.

International Organization for Standardization. (2020). ISO/IEC 27014:2020, Information security, cybersecurity and privacy protection, Governance of information security.

ISACA. (2019). COBIT 2019 framework: Governance and management objectives.